

CUADERNILLO DE ESTUDIO

CLASE 5

*“Gestión de riesgos I:
Metodología y Matriz $P \times I$ ”*

Profesor: Mg. Ing. Rodrigo Atilio Elgueta

Unidad: Unidad 2

Datos del/la estudiante

Nombre y apellido: _____

Grupo N.º: _____

Negocio Digital (TP): _____

Fecha: _____

Índice

1. ¿Qué es gestionar riesgos en un negocio digital?	2
2. El Ciclo de Gestión de Riesgos	2
3. La Matriz de Probabilidad e Impacto (P×I)	3
3.1. Escalas de medición	3
3.2. Mapa de Calor (Heatmap)	3
4. Opciones de Tratamiento (Las 4 T)	4
5. Taller Grupal: Matriz para el TP Integrador	5
6. Cuestionario 2 de autoevaluación	6
7. Glosario de la Clase 5	8
8. Espacio para notas y hallazgos	8

1. ¿Qué es gestionar riesgos en un negocio digital?

En las clases anteriores identificamos **activos**, **amenazas** y **vulnerabilidades**. Hoy damos el siguiente paso: ¿qué hacemos con todo eso?

Definición

La **Gestión de Riesgos** es el proceso de identificar, analizar y evaluar los riesgos para luego decidir cómo tratarlos, optimizando los recursos del negocio.

El objetivo NO es el “Riesgo Cero”. Eliminar todos los riesgos es técnicamente imposible y económicamente inviable (arruinaría la usabilidad y el presupuesto). El objetivo es **administrar el riesgo** hasta un nivel aceptable para el negocio, invirtiendo en controles solo donde el costo-beneficio lo justifique.

2. El Ciclo de Gestión de Riesgos

El proceso es iterativo y cíclico. Consta de 4 etapas principales:

El Proceso

1. **Identificación:** ¿Qué puede salir mal? (Listar activos, amenazas y vulnerabilidades).
2. **Análisis:** ¿Qué tan grave sería y qué tan probable es que ocurra? (Estimar Probabilidad e Impacto).
3. **Evaluación:** ¿Qué riesgos son prioritarios? (Usar la Matriz P×I para rankearlos).
4. **Tratamiento:** ¿Qué vamos a hacer al respecto? (Mitigar, Transferir, Aceptar o Evitar).

3. La Matriz de Probabilidad e Impacto ($P \times I$)

Para no tratar todos los riesgos por igual, los cruzamos en una matriz cualitativa. Esto nos da un **Mapa de Calor** que dicta la urgencia.

3.1 Escalas de medición

- **Probabilidad (P):** ¿Qué tan frecuente o fácil es que la amenaza explote la vulnerabilidad? (Baja, Media, Alta).
- **Impacto (I):** Si ocurre, ¿cuánto daño causa al negocio (financiero, legal, reputacional, operativo)? (Bajo, Medio, Alto).

3.2 Mapa de Calor (Heatmap)

Prob. ↓ Impacto →	Bajo	Medio	Alto
Alta	MEDIO	ALTO	CRÍTICO
Media	BAJO	MEDIO	ALTO
Baja	BAJO	BAJO	MEDIO

¿Cómo se lee?

- **Crítico / Alto:** Requieren tratamiento inmediato. No se pueden dejar pasar.
- **Medio:** Requieren un plan de acción a mediano plazo y monitoreo.
- **Bajo:** Se aceptan o se monitorean periódicamente.

4. Opciones de Tratamiento (Las 4 T)

Una vez evaluado el riesgo, la dirección del negocio debe decidir qué hacer. Existen 4 caminos clásicos:

Estrategia	Descripción	Ejemplo en Negocio Digital
Mitigar (Reducir)	Aplicar controles para bajar la Probabilidad o el Impacto.	Implementar MFA (doble factor) para reducir la probabilidad de robo de credenciales.
Transferir (Compartir)	Pasar el impacto financiero a un tercero.	Contratar un seguro de ciber-riesgo o tercerizar el hosting a un proveedor con SLA.
Aceptar (Tolerar)	Asumir el riesgo porque el control es más caro que el daño potencial.	Aceptar que el servidor se caiga 10 min al año porque un backup redundante cuesta u\$s 50k y la pérdida es de u\$s 500.
Evitar (Eliminar)	Dejar de realizar la actividad que genera el riesgo.	Decidir NO almacenar datos de tarjetas de crédito propios y usar siempre pasarelas como Mercado Pago o Stripe.

El BIA (Business Impact Analysis): Antes de decidir, hay que entender el impacto real en el negocio. Si el sistema de facturación cae 2 horas, ¿cuánto dinero se pierde? Eso dicta cuánto estamos dispuestos a invertir en prevenirlo.

5. Taller Grupal: Matriz para el TP Integrador

En sus grupos del Trabajo Práctico Integrador, identifiquen **3 riesgos clave** para el negocio digital que eligieron.

Pasos:

1. Describan el riesgo (Amenaza + Vulnerabilidad).
2. Identifiquen el Activo afectado.
3. Asígnenle un valor de Probabilidad (B/M/A) e Impacto (B/M/A).
4. Determinen el Nivel de Riesgo según el Mapa de Calor.
5. Propongan un Control y la Estrategia (Mitigar, Transferir, etc.).

Riesgo 1: _____

Activo: _____ **Prob:** [B / M / A] **Imp:** [B / M / A] **Nivel:** _____

Control propuesto: _____

Riesgo 2: _____

Activo: _____ **Prob:** [B / M / A] **Imp:** [B / M / A] **Nivel:** _____

Control propuesto: _____

Riesgo 3: _____

Activo: _____ **Prob:** [B / M / A] **Imp:** [B / M / A] **Nivel:** _____

Control propuesto: _____

Nota para el TP: Esta tabla es el borrador directo del Entregable 2 de su Trabajo Práctico Integrador. Guárdenla y sáquenle foto/escanéenla para su informe.

6. Cuestionario 2 de autoevaluación

Este cuestionario se realiza al cierre de la clase. **No es eliminatorio.** Usalo para medir cuánto entendiste antes del Parcial 1 (Clase 6). Las respuestas correctas están al final.

1. El proceso de gestión de riesgos sigue, en orden:
 - a) Tratamiento, identificación, análisis, evaluación
 - b) Identificación, análisis, evaluación, tratamiento
 - c) Evaluación, identificación, tratamiento, análisis
 - d) No sigue un orden específico
2. En una matriz de probabilidad e impacto, un riesgo con alta probabilidad y alto impacto debe:
 - a) Ignorarse por ser poco común
 - b) Priorizarse para tratamiento inmediato
 - c) Transferirse siempre a un seguro
 - d) Aceptarse sin más
3. BIA significa:
 - a) Business Impact Analysis (Análisis de Impacto al Negocio)
 - b) Basic Information Access
 - c) Business Information Audit
 - d) Backup and Incident Assessment
4. Un ejemplo de control técnico es:
 - a) Una política firmada por empleados
 - b) Un firewall o un sistema de autenticación multifactor (MFA)
 - c) Una capacitación anual
 - d) Un cerco perimetral
5. Un ejemplo de control humano/organizativo es:
 - a) Antivirus
 - b) Capacitación en concientización de seguridad
 - c) Cifrado de disco
 - d) Cámaras de seguridad
6. ISO/IEC 27001 es principalmente:
 - a) Una ley argentina de protección de datos

- b) Una norma internacional sobre sistemas de gestión de seguridad de la información
- c) Un lenguaje de programación seguro
- d) Un tipo de malware

7. “Tratar” un riesgo puede significar (elegí todas las correctas):

- a) Evitarlo
- b) Mitigarlo
- c) Transferirlo
- d) Aceptarlo

8. Verdadero o Falso: la gestión de riesgos es un proceso que se hace una sola vez y no se repite. ☐ Verdadero ☐ Falso

✓ Clave de respuestas

1. **b)** Identificación, análisis, evaluación, tratamiento.
2. **b)** Priorizarse para tratamiento inmediato.
3. **a)** Business Impact Analysis.
4. **b)** Un firewall o un sistema MFA.
5. **b)** Capacitación en concientización.
6. **b)** Una norma internacional (SGSI).
7. **a, b, c, d** (Todas son estrategias válidas de tratamiento).
8. **Falso.** Es un proceso continuo y cíclico que debe revisarse periódicamente.

7. Glosario de la Clase 5

Término	Definición en una línea
Gestión de Riesgos	Proceso de identificar, analizar, evaluar y tratar riesgos.
Matriz P×I	Herramienta visual para cruzar Probabilidad e Impacto.
Mapa de Calor	Representación gráfica de la matriz con colores de urgencia.
BIA	Análisis de Impacto al Negocio (cuánto cuesta que algo se detenga).
Mitigar	Aplicar controles para reducir la probabilidad o el impacto.
Transferir	Traspasar el impacto financiero (ej. seguros, tercerización).
Aceptar	Asumir el riesgo porque el control es más caro que el daño.
Evitar	Eliminar la actividad que genera el riesgo.
ISO/IEC 27001	Norma internacional para Sistemas de Gestión de Seguridad (SGSI).

8. Espacio para notas y hallazgos

Anotá aquí dudas sobre la matriz, ideas de controles para tu TP Integrador o conceptos para el Parcial 1.